Mass Assignment Security Testing

Educational Bug Bounty Series • Authorized Security Research Only

■ Mass Assignment — Security Testing

Contributed by Cyber_Spy.404 | Educational Bug Bounty Series

Scope and ethics: *Use a test account in an authorized environment. Never attempt to grant yourself real administrative privileges.*

■ Executive Summary

Mass assignment occurs when client input is automatically mapped to internal model properties without an explicit allowlist. The supplied three-page *mass.pdf* focuses on registration and account workflows where role, administrator, or organization-access fields might be accepted unintentionally.

■ Core Testing Methodology

1. Identify registration, profile, password-reset, email-change, and organization endpoints.
2. Record the documented fields for a normal request.
3. Establish a baseline with a synthetic test account.
4. In staging, submit a harmless unknown field and verify it is rejected or ignored.
5. Confirm role, permission, ownership, and verification fields are assigned only server-side.
6. Check field naming/casing and nested-object handling.
7. Verify sensitive actions still require independent authorization.
8. Record sanitized evidence and retest.

■ High-Value Bug Bounty Tips & Edge Cases

• The source shows registration examples with added role/admin-like fields.

• Alternate capitalization or field aliases can reveal inconsistent model binding.

• Organization membership should use a verified invitation or administrative workflow.

• Sensitive email/password changes require the intended identity verification.

• Unknown fields should be rejected or ignored consistently.

• The source does not establish a vulnerability in a particular application.

■■ Educational Checklists & Safe Examples

```
POST /api/v1/register HTTP/1.1
Host: example.com
Content-Type: application/json

{
  "username": "[TEST-USERNAME]",
  "email": "[TEST-EMAIL]",
  "password": "[TEST-PASSWORD]"
}
```

• [ ] Endpoints allowlist writable fields.

• [ ] Roles/admin/ownership fields remain server-controlled.

• [ ] Nested objects are validated recursively.

• [ ] Unknown fields are handled consistently.

• [ ] Authorization is independent of input validation.

■■ Mitigation & Remediation

Use explicit DTOs/serializers and allowlisted fields, separate public profile models from internal authorization models, assign roles only through trusted workflows, validate nested data, and regression-test unexpected privileged fields.

■ Source Notes

Based on the supplied three-page *mass.pdf*. Pages 1–2 cover account registration, organization access, password reset, login, email/username changes, and examples containing extra privilege-related fields. Page 3 has limited readable text in the preview.

Educational use only. Avoid unauthorized privilege testing.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.